

Explainable Phishing URL and Website Detection

Final Project Report

Machine Learning Security Project

Final implementation: 16 August 2026

Abstract

This project investigates phishing detection using URL text, webpage-derived tabular features, classical machine learning, gradient boosting, transformer embeddings, and SHAP explanations. The PhiUSIIL dataset contains 235,795 labelled records: 100,945 phishing and 134,850 legitimate. Initial results were unusually close to perfect, so the project widened its leakage and target-proxy audit before training advanced models. The final evaluation uses deterministic train, validation, and test splits grouped by normalized hostname, with zero exact-URL or normalized-host overlap.

Under this audited protocol, LightGBM achieved test macro F1 of 0.999971 using URL and webpage-derived fields. XGBoost achieved 0.999913. A raw URL character TF-IDF model achieved 0.997747 and outperformed a pinned all-MiniLM-L6-v2 embedding model at 0.980200. LightGBM was selected for dataset-level SHAP analysis. The interactive demo exposes all trained models, approximates page features through guarded retrieval, and abstains when models disagree. Results remain specific to one static dataset and do not establish real-world deployment performance.

1. Problem and objectives

Phishing links imitate trusted services to steal credentials, money, or personal data. Blacklists are useful but reactive: new URLs may not yet be listed. Machine learning can identify patterns associated with phishing, but unusually high evaluation scores can also result from duplicated entities, target-derived features, or collection bias.

The project objectives were to:

1. Explore and prepare the PhiUSIIL dataset.
2. Establish classical machine-learning baselines.
3. audit data leakage and target proxies before stronger modelling.
4. Compare XGBoost and LightGBM under one locked protocol.
5. Compare lightweight URL-text and transformer representations.
6. Explain the strongest audited tabular model with SHAP.
7. Build a local multi-model demo with guarded live-page retrieval and clear uncertainty.

2. Dataset and ethics

The UCI PhiUSIIL Phishing URL Dataset contains 235,795 rows and 56 columns in the local source file. Label 0 means phishing and label 1 means legitimate. The class balance is 42.81% phishing and 57.19% legitimate. The dataset combines URL measurements with webpage-related fields such as line counts, images, scripts, references,

forms, and metadata indicators.

The dataset is licensed under CC BY 4.0. Public phishing records must be handled carefully. The demo uses a defanged, non-clickable historical sample and makes no claim about its current status. Live retrieval is limited to explicit HTTP/S analysis and is guarded against private-network access and oversized responses.

3. Leakage audit and evaluation protocol

The original random-row split contained measurable overlap: 90 exact URLs and 1,684 domains were shared between its train and test data. That protocol is preserved only as historical evidence.

The replacement protocol is `stratified_normalized_host_group_70_15_15_v1`. It groups rows by normalized hostname and assigns groups deterministically while approximately preserving class balance:

Split	Rows	Normalized hosts	Phishing	Legitimate
Train	165,055	153,614	70,662	94,393
Validation	35,369	32,933	15,141	20,228
Test	35,371	32,547	15,142	20,229

The audit asserts zero normalized-host and exact-URL overlap across these splits. Training-only transforms are used during tuning. Candidate selection uses validation macro F1, phishing recall, ROC-AUC, then deterministic candidate ID. The frozen test set is used once per locked model configuration.

Raw identifiers and text (FILENAME, URL, Domain, and Title) are excluded from tabular models. Four unresolved derived features are quarantined: `URLSimilarityIndex`, `CharContinuationRate`, `TLDLegitimateProb`, and `URLCharProb`. Raw TLD remains categorical and is one-hot encoded using training-fitted categories.

The audit also found very strong individual separation for `LineOfCode`, `NoOfExternalRef`, and `NoOfImage`. These may be meaningful indicators, collection effects, or unresolved proxies. Statistical association cannot distinguish those explanations by itself.

4. Models and reproducibility

Classical audited baselines were Logistic Regression, Decision Tree, and Random Forest. Advanced models were XGBoost 3.2.0 and LightGBM 4.7.0. Each advanced algorithm used four declared structural candidates and one train-derived balanced-weight ablation. Final models were refitted on train plus validation only after selection.

The URL-text experiment used two representations:

- Character TF-IDF: character-within-word n-grams of length 3–5, maximum 150,000 train-fitted features, followed by Logistic Regression.
- Sentence Transformer: `sentence-transformers/all-MiniLM-L6-v2`, immutable revision `1110a243fdf4706b3f48f1d95db1a4f5529b4d41`, 384 normalized float32 dimensions, followed by Logistic Regression.

The same bounded Logistic Regression values ($C = 0.25, 1.0, 4.0$) were validated for each representation. Saved manifests record parameters, package versions, source and split hashes, timings, and artifact hashes. Saved bundles passed prediction round-trip checks. Embedding caches fail closed when row order, row hashes, shape, precision, revision, or device metadata differ.

MiniLM is designed for sentences and short paragraphs rather than URL syntax. Its inclusion is an exploratory contextual baseline, not an assumption that transformers must outperform character features.

5. Results

All values below come from the 35,371-row frozen audited test split.

Model	Input scope	Macro F1	ROC-AUC	Balanced accuracy	Phishing recall
LightGBM	URL and webpage-derived fields	0.999971	1.000000	0.999967	0.999934
XGBoost	URL and webpage-derived fields	0.999913	1.000000	0.999918	0.999934
Random Forest	URL and webpage-derived fields	0.999856	1.000000	0.999843	0.999736
Logistic Regression	URL and webpage-derived fields	0.999538	0.999996	0.999521	0.999340
Decision Tree	URL and webpage-derived fields	0.998845	0.998845	0.998845	0.998679
Character TF-IDF + LR	Raw URL only	0.997747	0.999446	0.997424	0.994849
MiniLM embeddings + LR	Raw URL only	0.980200	0.996591	0.979598	0.972395

LightGBM made one phishing-to-legitimate error and no legitimate-to-phishing errors in this test split. TF-IDF made 78 phishing-to-legitimate errors and no legitimate-to-phishing errors. MiniLM made 418 phishing-to-legitimate and 267 legitimate-to-phishing errors.

The tabular and URL-only inputs are not equivalent. The comparison shows an accuracy-versus-operability trade-off: LightGBM is the strongest dataset model, but its webpage-derived inputs require extraction logic. The demo implements a disclosed approximation because the dataset does not publish an executable extraction contract. TF-IDF works directly on pasted URL text without network access. MiniLM was both more computationally expensive and less accurate than TF-IDF.

6. Explainability

SHAP 0.51.0 was applied to the locked LightGBM preprocessing-plus-model bundle. A deterministic, class-stratified background of 128 train-plus-validation rows and an explanation cohort of 256 frozen-test rows were used. Forty-seven raw inputs expanded to 709 transformed columns; TLD one-hot attributions were grouped back to the original feature.

The highest mean-absolute phishing-probability attributions were:

Feature group	Mean absolute SHAP
LineOfCode	0.111589

Feature group	Mean absolute SHAP
IsHTTPS	0.077195
NoOfSelfRef	0.057711
NoOfImage	0.030258
NoOfOtherSpecialCharsInURL	0.029064
NoOfDigitsInURL	0.022759
NoOfExternalRef	0.022510
LetterRatioInURL	0.021388

Global bar and beeswarm plots were saved, together with local waterfall plots for representative phishing, representative legitimate, and closest-to-boundary cases. No false positive or false negative occurred in the 256-row explanation cohort, so error-specific local cases were unavailable. Maximum probability additivity error was $1.279e-08$.

SHAP explains this model on this background distribution. It does not prove that a feature causes phishing, validate feature provenance, or establish generalization. The dominance of webpage-volume fields reinforces the collection-bias warning.

7. Demo application

The demo uses FastAPI 0.139.2 with responsive vanilla HTML, CSS, and JavaScript. Its dropdown exposes seven unique models under plain names: TF-IDF, MiniLM, Logistic Regression, Decision Tree, Random Forest, XGBoost, and LightGBM. Automatic and Compare All are convenience modes. Automatic combines TF-IDF and MiniLM URL evidence with five page-feature models. It reports individual scores, agreement, feature coverage, warnings, and an uncertain verdict when evidence conflicts.

Safety and reliability controls include:

- HTTP/HTTPS-only validation, valid hostnames, 2,048-character URL limit, and rejection of embedded credentials.
- Extra JSON fields rejected and large declared request bodies rejected.
- Explicit trusted hosts, same-origin assets, no API documentation routes, and restrictive browser security headers.
- No URL echo in API responses or validation errors.
- Guarded server-side retrieval: public IPs only, address pinning, redirect revalidation, standard ports, bounded redirects and response size, HTML-only content, and no JavaScript execution.
- Seven semantic page fields are explicitly disclosed approximations.
- Clear warnings that labels are signals and scores are not calibrated real-world risk.

Live controls on 16 August 2026 classified Google as legitimate with combined phishing score 0.136 and Python.org as legitimate with score 0.022. GitHub produced score 0.831 but only 57% model agreement, so the application returned uncertain rather than phishing. TF-IDF alone scored GitHub at nearly 1.0 while audited Logistic Regression scored it near 0.0, demonstrating severe distribution shift and the value of abstention.

8. Limitations

1. One static dataset is insufficient for deployment claims.
2. Normalized-host grouping does not merge sibling subdomains under a registered domain.

3. Strong webpage-derived features may encode corpus construction patterns.
4. Weighted boosted probabilities are not calibrated real-world risk.
5. Live analysis excludes JavaScript-rendered content, sender context, reputation, domain age, and time.
6. MiniLM is not URL-specific and may tokenize or truncate URLs poorly.
7. The demo is local and educational; it is not a browser extension, gateway, or production security control.
8. Historical public labels do not prove current maliciousness or safety.
9. Guarded outbound retrieval reduces SSRF risk but is not sufficient for exposing this educational service directly to untrusted public traffic.

9. Conclusion and future work

The project met its implementation objectives while correcting the most serious evaluation risk: row and domain overlap. Both XGBoost and LightGBM were trained under the same audited protocol. LightGBM produced the strongest dataset score, while character TF-IDF was the best raw-URL model and clearly outperformed the transformer embedding baseline. SHAP highlighted reliance on potentially corpus-specific webpage fields. The FastAPI demo now makes that conflict inspectable through model switching, guarded extraction, and explicit abstention without overstating its authority.

Future work should prioritize independent, time-separated evaluation; registered-domain grouping with a pinned Public Suffix List; formal score calibration; a validated reference extractor; and privacy-reviewed reputation or domain-age evidence. More model complexity should be considered only after those validity gaps are addressed.

References

1. Prasad, A. and Chandra, S., "PhiUSIIL: A diverse security profile empowered phishing URL detection framework based on similarity index and incremental learning," *Computers & Security*, 2024.
2. UCI Machine Learning Repository, "PhiUSIIL Phishing URL Dataset," dataset 967, CC BY 4.0.
3. Chen, T. and Guestrin, C., "XGBoost: A Scalable Tree Boosting System," KDD, 2016.
4. Ke, G. et al., "LightGBM: A Highly Efficient Gradient Boosting Decision Tree," NeurIPS, 2017.
5. Lundberg, S. and Lee, S-I., "A Unified Approach to Interpreting Model Predictions," NeurIPS, 2017.
6. Wang, W. et al., "MiniLM: Deep Self-Attention Distillation for Task-Agnostic Compression of Pre-Trained Transformers," NeurIPS, 2020.

Artifact appendix

Primary reproducibility evidence is stored in `data/processed/audited/split_manifest.json`, `reports/model_results/model_comparison.csv`, `reports/transformer_experiments/url_text_results.csv`, and `reports/explainability/`. Model bundles and manifests are in `models/advanced/` and `models/url_text/`.